

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM ENGENHARIA DE SOFTWARE

BRUNO HIDEO SILVA SHIRAISHI
DIEGO ALVES DA SILVA FAGUNDES
GUSTAVO QUINTILIANO ERNESTO DOS SANTOS
PIETRO LOPES NOZELLA SOUSA

FALLSENSE
DOCUMENTAÇÃO TÉCNICO-CIENTÍFICA

MOGI DAS CRUZES - SP

2026

BRUNO HIDEO SILVA SHIRAISHI
DIEGO ALVES DA SILVA FAGUNDES
GUSTAVO QUINTILIANO ERNESTO DOS SANTOS
PIETRO LOPES NOZELLA SOUSA

FALLSENSE
DOCUMENTAÇÃO TÉCNICO-CIENTÍFICA

Documentação apresentada para o Prof. Fabiano Bezerra Menegidio sobre o projeto relacionado à disciplina de Políticas de segurança da informação do curso de Bacharelado em Engenharia de Software.

MOGI DAS CRUZES - SP

2026

SUMÁRIO

1 VISÃO GERAL DO SISTEMA.....	4
2 DIAGRAMA DE ARQUITETURA	5
3 FLUXO DE AUTENTICAÇÃO E DADOS DOCUMENTADOS	6
3.1 Fluxo de Cadastro	6
3.2 Fluxo de Login com 2FA	6
3.3 Fluxo de Logout.....	7
3.4 Fluxo de Recuperacao de Senha	7
3.5 Fluxo de Dados do Sistema	8
4 GESTÃO DE CREDENCIAIS DOCUMENTADAS.....	9
4.1 Armazenamento Seguro no Dispositivo Móvel (Frontend).....	9
4.2 Proteção de Variáveis de Ambiente e Senhas (Backend)	9
4.3 Credenciais no Dispositivo IoT (Hardware)	10
5 USO DE CRIPTOGRAFIA DOCUMENTADO.....	11
5.1 Criptografia em Trânsito (Comunicação Segura).....	11
5.2 Criptografia em Repouso (Persistência de Dados)	11
5.3 Autenticação Baseada em Tokens (JWT)	12
6 IDENTIFICAÇÃO DOS ATIVOS DO SISTEMA.....	13
6.1 Inventário Geral de Ativos do Ecossistema.....	13
6.2 Classificação de Criticidade dos Ativos	14
6.3 Detalhamento dos Ativos Críticos.....	14
6.3.1 Ativos De Hardware (Físicos)	14
6.3.2 Ativos De Software (Lógicos)	14
6.3.3 Ativos de Informação (Dados)	15
6.4 Matriz de Riscos dos Ativos	15
6.4.1 Critérios de Avaliação de Risco.....	15
7 USO DE ARTIGOS CIENTÍFICOS E NORMAS TÉCNICAS	17
Referências	18

1 VISÃO GERAL DO SISTEMA

O FallSense é um sistema de monitoramento voltado a detecção de quedas, composto por três partes principais: uma pulseira sensorial, uma API backend e um aplicativo mobile. A solução tem como objetivo registrar eventos de risco, como quedas, e disponibilizar essas informações para o usuário responsável por meio do aplicativo.

A pulseira sensorial representa a camada de coleta de dados. Ela é responsável por identificar eventos físicos relacionados ao movimento do usuário monitorado, como impactos ou possíveis quedas. Esses eventos são enviados para o sistema, onde ficam associados a uma pulseira cadastrada e a uma pessoa monitorada.

O backend é desenvolvido em Python com FastAPI e atua como camada central da aplicação. Ele gerencia autenticação, usuários, pessoas monitoradas, pulseiras, eventos de telemetria, logs de auditoria e recuperação de senha. O armazenamento dos dados é feito em banco PostgreSQL/Supabase, usando SQLAlchemy como camada ORM.

O aplicativo mobile é desenvolvido em Flutter. Ele permite que o usuário realize cadastro, login com autenticação em dois fatores, consulte o perfil, visualize pessoas monitoradas, dispositivos vinculados e eventos recentes. A comunicação entre o app e o backend ocorre via requisições HTTP/HTTPS usando tokens JWT para autenticação.

Principais módulos do sistema:

- Aplicativo Flutter: interface do usuário, login, cadastro, 2FA, perfil e visualização de dados.
- API FastAPI: autenticação, regras de negócio, validação, persistência e segurança.
- Banco PostgreSQL/Supabase: armazenamento de usuários, pulseiras, pessoas monitoradas, eventos e auditoria.
- Serviço de e-mail Brevo: envio de códigos de recuperação de senha.
- Pulseira IoT: origem dos dados sensoriais e eventos de queda.

2 DIAGRAMA DE ARQUITETURA

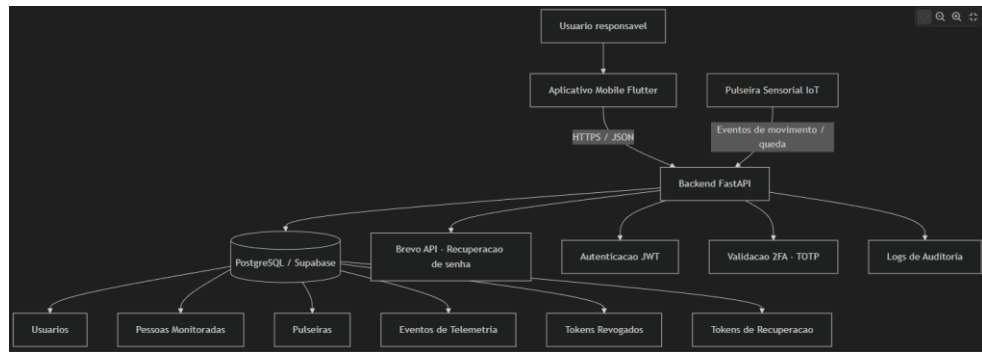


Figura 1 – Diagrama de arquitetura

A arquitetura segue uma divisão simples em camadas. O aplicativo mobile não acessa diretamente o banco de dados; toda comunicação passa pela API. Isso centraliza as regras de segurança, validação e autorização no backend.

O backend valida o token JWT em rotas protegidas, consulta o banco de dados e retorna apenas os dados vinculados ao usuário autenticado. Dessa forma, um responsável só consegue acessar as pessoas monitoradas, pulseiras e eventos associados à sua própria conta.

3 FLUXO DE AUTENTICAÇÃO E DADOS DOCUMENTADOS

3.1 FLUXO DE CADASTRO

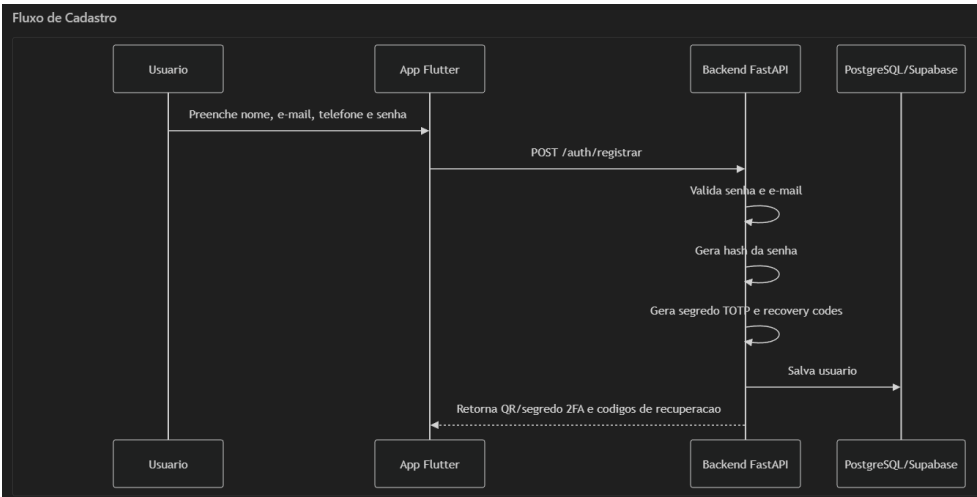


Figura 2 – Fluxo de cadastro

No cadastro, a senha não é armazenada em texto puro. O backend aplica hash usando Argon2id. Também são gerados o segredo TOTP para autenticação em dois fatores e códigos de recuperação.

3.2 FLUXO DE LOGIN COM 2FA

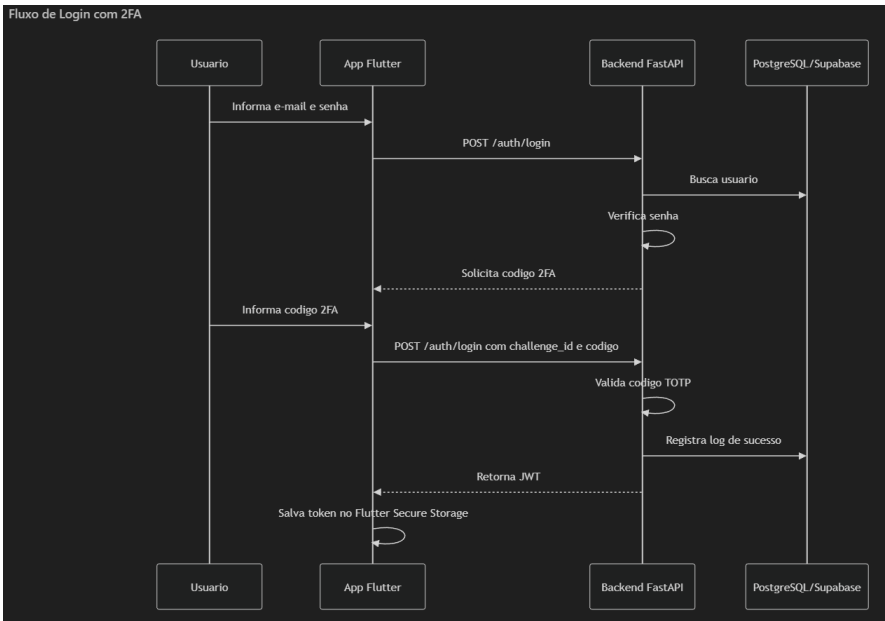


Figura 3 – Fluxo de login com 2FA

O login ocorre em duas etapas. Primeiro, o backend valida e-mail e senha. Em seguida, solicita o código 2FA. Após a validação do código, o backend emite um token JWT com validade de 60 minutos.

3.3 FLUXO DE LOGOUT

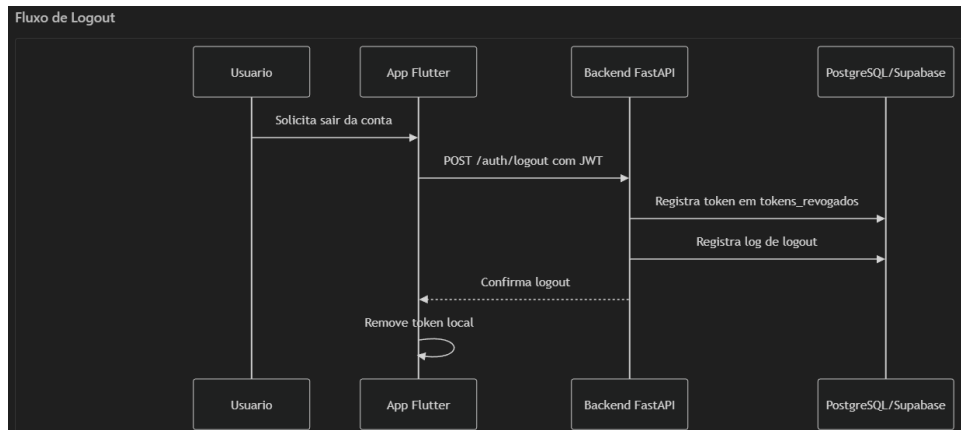


Figura 4 – Fluxo de logout

O logout invalida o token atual por meio de uma blacklist no banco de dados. Mesmo que o JWT ainda não tenha expirado, ele deixa de ser aceito pela API.

3.4 FLUXO DE RECUPERACAO DE SENHA

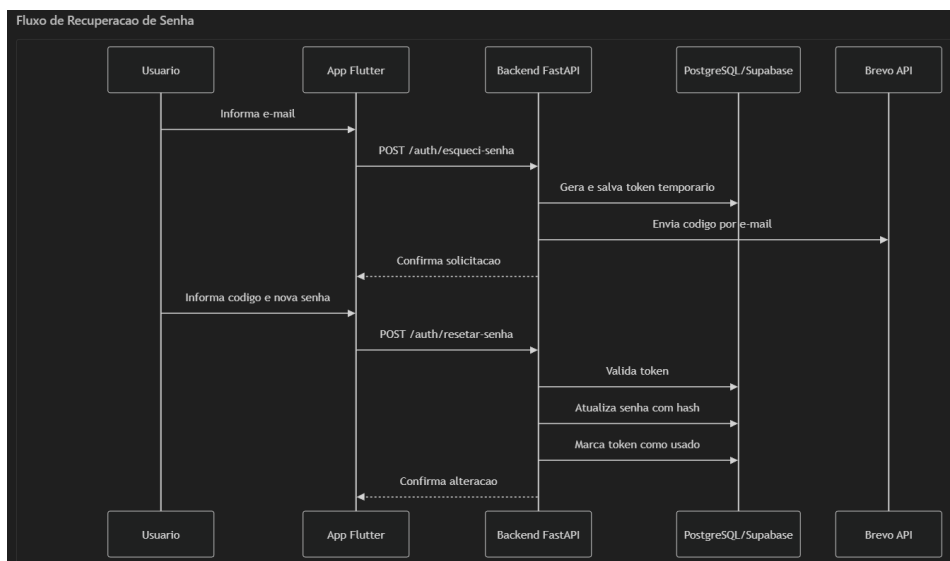


Figura 5 – Fluxo de recuperação de senha

O código de recuperação possui validade de 15 minutos e uso único. Após a redefinição da senha, o token é marcado como utilizado.

3.5 FLUXO DE DADOS DO SISTEMA

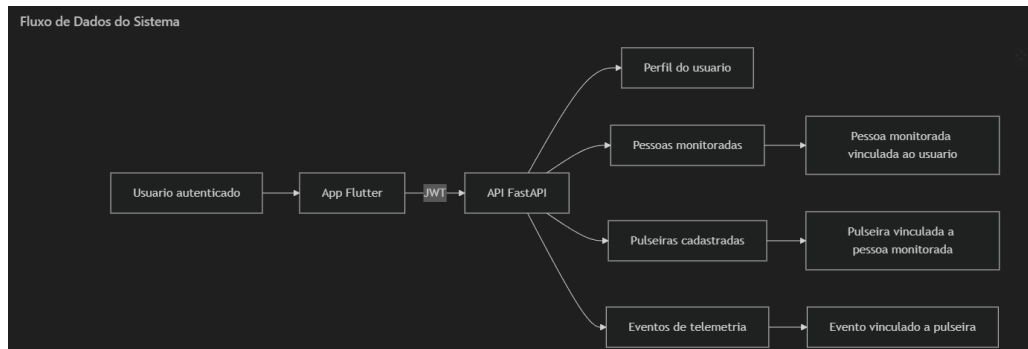


Figura 6 – Fluxo de dados do sistema

O fluxo de dados respeita o vínculo entre as entidades:

- Um usuário responsável pode cadastrar pessoas monitoradas.
- Cada pessoa monitorada pode ter uma pulseira vinculada.
- Cada pulseira pode gerar eventos de telemetria.
- Os eventos só são retornados ao usuário responsável pela pessoa associada a pulseira.

Principais entidades persistidas:

- usuarios_api
- pessoa_monitorada
- pulseira
- telemetria_evento
- logs_auditoria
- tokens_revogados
- tokens_recuperacao

Esse modelo mantém a rastreabilidade dos eventos e limita o acesso aos dados conforme o usuário autenticado.

4 GESTÃO DE CREDENCIAIS DOCUMENTADAS

A gestão de credenciais no ecossistema do projeto FallSense adota políticas rígidas de segurança e criptografia para garantir que chaves de API, senhas de usuários e tokens de autenticação não fiquem expostos no código-fonte ou em armazenamento local vulnerável. A arquitetura do sistema distribui essa responsabilidade em três camadas integradas de segurança: Mobile/Frontend, API/Backend e Hardware/Firmware.

4.1 ARMAZENAMENTO SEGURO NO DISPOSITIVO MÓVEL (FRONTEND)

No aplicativo desenvolvido em Flutter, os dados sensíveis de sessão do usuário como tokens JWT (JSON Web Tokens) emitidos após a autenticação do usuário não são armazenados em arquivos de preferência comuns (SharedPreferences), devido à ausência de criptografia nativa nesses métodos de persistência. O sistema utiliza a biblioteca flutter_secure_storage, que atua como uma camada de abstração sobre os mecanismos de armazenamento seguro e isolado nativos de cada sistema operacional móvel.

- Android: Utiliza a Android Keystore System, empregando mecanismos criptográficos seguros, incluindo algoritmos simétricos como AES, mantendo as chaves de criptografia isoladas do restante do sistema de arquivos do aparelho.
- iOS: Utiliza o mecanismo Keychain, garantindo que as informações de autenticação persistam de forma criptografada por hardware, protegendo os dados de sessão contra técnicas de engenharia reversa ou inspeção de memória.

4.2 PROTEÇÃO DE VARIÁVEIS DE AMBIENTE E SENHAS (BACKEND)

No servidor desenvolvido em Python, nenhuma credencial de banco de dados, chaves secretas de assinatura de tokens ou chaves de serviços de terceiros (como provedores de SMS e e-mail) é inserida diretamente no código-fonte (hardcoded).

- Isolamento de Credenciais: O backend utiliza o padrão de Variáveis de Ambiente gerenciadas por arquivos .env em ambiente de desenvolvimento local, os quais são ignorados pelo Git. Em ambiente de produção, essas variáveis são injetadas diretamente na plataforma de hospedagem (Render), impedindo que credenciais críticas sejam expostas publicamente em repositórios do GitHub.

- Criptografia de Senhas (Hashing): As senhas dos usuários não são armazenadas em texto claro no banco de dados. O sistema utiliza algoritmos de hashing criptográfico de via única, como bcrypt ou bibliotecas derivadas do Werkzeug, aplicando funções de dispersão associadas ao uso de Salt (valores aleatórios adicionados à senha antes da geração do hash), neutralizando ataques de dicionário e tabelas de arco-íris (Rainbow Tables).

4.3 CREDENCIAIS NO DISPOSITIVO IOT (HARDWARE)

No firmware gravado no microcontrolador ESP32 da pulseira, as credenciais de rede (SSID e senha do Wi-Fi local onde o dispositivo opera) e os tokens de comunicação com a API do FallSense exigem cuidados adicionais de segurança.

- Compilação Segura: As credenciais de desenvolvimento são isoladas em arquivos de configuração separados, como cabeçalhos .h ou definições do PlatformIO, os quais permanecem fora do controle de versão por meio do uso do arquivo .gitignore.

- Persistência Local: Caso o dispositivo necessite armazenar credenciais de redes dinâmicas em produção, utiliza-se a memória não volátil NVS (Non-Volatile Storage) do ESP32 através de partições criptografadas nativas do chip, dificultando a extração física das credenciais caso o hardware da pulseira seja violado. Essas práticas permitem que o ecossistema FallSense mantenha um modelo de proteção em múltiplas camadas, reduzindo significativamente riscos relacionados à exposição de credenciais, sequestro de sessão e acesso não autorizado aos componentes do sistema.

5 USO DE CRIPTOGRAFIA DOCUMENTADO

O projeto FallSense emprega mecanismos criptográficos estabelecidos pela indústria para garantir os três pilares fundamentais da segurança da informação: confidencialidade, integridade e autenticidade. A aplicação de criptografia ocorre tanto para a proteção de dados em trânsito (trafegando pela rede) quanto para dados em repouso (armazenados no banco de dados).

5.1 CRIPTOGRAFIA EM TRÂNSITO (COMUNICAÇÃO SEGURA)

Toda a comunicação externa entre os componentes do ecossistema FallSense englobando as requisições do aplicativo móvel (Flutter), os envios de dados telemétricos do microcontrolador (ESP32) e as respostas da API (Python) é obrigatoriamente protegida por mecanismos de criptografia de transporte.

- Protocolo HTTPS/TLS: As requisições HTTP utilizadas em ambiente de desenvolvimento local são substituídas pelo protocolo seguro HTTPS em ambiente de produção na plataforma Render. Utiliza-se a criptografia de transporte TLS 1.2 / 1.3 (Transport Layer Security), garantindo que, caso um atacante intercepte os pacotes de rede em ataques do tipo Man-in-the-Middle, apenas dados cifrados sejam visualizados, impossibilitando a leitura de informações sensíveis relacionadas à saúde do idoso, alertas de quedas e dados cadastrais.

5.2 CRIPTOGRAFIA EM REPOUSO (PERSISTÊNCIA DE DADOS)

Os dados armazenados no servidor e no banco de dados recebem tratamento criptográfico para mitigar riscos relacionados a vazamentos decorrentes de acessos indevidos à infraestrutura física ou lógica.

- Funções de Hash de Via Única: Para a persistência de senhas no banco de dados, o sistema utiliza mecanismos de hashing criptográfico de via única. Após a geração do hash com Salt, o sistema não armazena nem conhece a senha real do usuário. A validação durante o login ocorre pela comparação entre o hash gerado da senha digitada e o hash previamente armazenado, preservando a integridade do segredo.

- Segurança na Nuvem: O banco de dados hospedado em ambiente de nuvem utiliza criptografia nativa em volumes de armazenamento (encryption at rest),

garantindo que os arquivos físicos do banco de dados permaneçam cifrados diretamente na infraestrutura da provedora de nuvem.

5.3 AUTENTICAÇÃO BASEADA EM TOKENS (JWT)

Para garantir que apenas usuários legítimos acessem os dados sensíveis e históricos da pulseira sensorial, o sistema utiliza assinatura criptográfica simétrica para autenticação baseada em tokens JWT (JSON Web Token).

- **Assinatura Digital:** Após a autenticação bem-sucedida, o backend desenvolvido em Python gera um token JWT compactado e assinado digitalmente utilizando o algoritmo HS256 (HMAC com SHA-256), empregando uma chave secreta robusta armazenada de forma segura nas variáveis de ambiente da plataforma Render.

- **Integridade do Token:** O aplicativo Flutter envia esse token no cabeçalho HTTP (Authorization Header) em todas as requisições subsequentes. O backend valida a assinatura criptográfica antes de conceder acesso aos recursos protegidos. Qualquer tentativa de alteração maliciosa no conteúdo do token invalida imediatamente a assinatura digital, bloqueando o acesso. Além disso, os tokens possuem tempo de expiração configurado, reduzindo a janela de exposição em caso de comprometimento do identificador de sessão.

A adoção dessas práticas criptográficas permite que o FallSense mantenha um ambiente seguro para transmissão, armazenamento e autenticação de dados sensíveis, alinhando o sistema às boas práticas modernas de segurança da informação e conformidade com a LGPD.

6 IDENTIFICAÇÃO DOS ATIVOS DO SISTEMA

A identificação e a classificação dos ativos representam etapas fundamentais para a gestão de riscos, segurança da informação e conformidade legal no projeto FallSense. O processo de inventário dos ativos permite compreender quais componentes sustentam o funcionamento do ecossistema, bem como avaliar seus níveis de criticidade, dependência operacional e impacto sobre a proteção de dados pessoais. A identificação dos ativos também considera os princípios de confidencialidade, integridade e disponibilidade das informações tratadas pelo sistema, garantindo alinhamento com boas práticas de governança de TI, segurança da informação e conformidade com a Lei Geral de Proteção de Dados (LGPD). Os ativos do ecossistema FallSense foram categorizados em três grandes grupos: Ativos de Hardware (Físicos), Ativos de Software (Lógicos) e Ativos de Informação (Dados).

6.1 INVENTÁRIO GERAL DE ATIVOS DO ECOSSISTEMA

Identificador	Nome do Ativo	Categoria	Descrição / Função no Sistema
ACT-HW-01	Microcontrolador ESP32	Hardware	Microcontrolador da pulseira responsável por processar e transmitir dados via Wi-Fi.
ACT-HW-02	Sensor MPU6050	Hardware	Sensor que detecta movimentos, impactos e aceleração do usuário.
ACT-SW-01	Aplicativo Mobile (Flutter)	Software	Aplicativo para monitoramento, gerenciamento de perfil e recebimento de alertas.
ACT-SW-02	API / Backend (Python)	Software	Servidor responsável pelo processamento, autenticação e regras do sistema.
ACT-SW-03	Banco de Dados Relacional	Software	Sistema em nuvem responsável pelo armazenamento seguro dos dados.
ACT-INF-01	Cadastro de Usuários	Informação	Dados pessoais dos usuários protegidos por criptografia.
ACT-INF-02	Contatos de Emergência	Informação	Relação de contatos autorizados para recebimento de alertas.
ACT-INF-03	Histórico de Telemetria e Quedas	Informação	Histórico de eventos, alertas e dados sensoriais para rastreabilidade e conformidade.

Figura 7 – Inventário geral de ativos do ecossistema

6.2 CLASSIFICAÇÃO DE CRITICIDADE DOS ATIVOS

Nível de Criticidade	Descrição
Alto	Ativos cuja indisponibilidade, vazamento ou comprometimento impactam diretamente a segurança, privacidade ou funcionamento do sistema.
Médio	Ativos importantes para a operação do ecossistema, porém com impacto parcial em caso de falha ou indisponibilidade temporária.
Baixo	Ativos auxiliares cujo comprometimento possui impacto reduzido na continuidade operacional do sistema.

Figura 8 – Classificação de criticidade dos ativos

Os ativos classificados como ACT-INF-01, ACT-INF-02 e ACT-INF-03 são considerados ativos de alta criticidade devido ao tratamento de dados pessoais, informações de emergência e registros relacionados à saúde e segurança dos usuários, estando diretamente sujeitos às diretrizes estabelecidas pela LGPD.

6.3 DETALHAMENTO DOS ATIVOS CRÍTICOS

6.3.1 Ativos De Hardware (Físicos)

Microcontrolador ESP32 (ACT-HW-01): Elemento central do hardware vestível do projeto FallSense. O ESP32 possui conectividade Wi-Fi nativa e baixo consumo energético, sendo responsável pela coleta dos dados provenientes dos sensores embarcados, processamento inicial das informações e transmissão segura das leituras para o backend.

Sensor Inercial MPU6050 (ACT-HW-02): Circuito integrado responsável pela captura de movimentos do usuário, permitindo transformar movimentos físicos em dados relacionados à aceleração e velocidade angular.

6.3.2 Ativos De Software (Lógicos)

Aplicativo Mobile em Flutter (ACT-SW-01): Frontend do ecossistema FallSense executado em dispositivos móveis, permitindo monitoramento e recebimento de notificações em tempo real.

API Backend em Python (ACT-SW-02): Hospedada na plataforma Render, centraliza a inteligência operacional do sistema, valida autenticações e processa requisições do hardware IoT.

Banco de Dados em Nuvem (ACT-SW-03): Responsável pela persistência das informações críticas do ecossistema, garantindo integridade e disponibilidade dos dados.

6.3.3 Ativos de Informação (Dados)

Dados Cadastrais e de Emergência: Conjunto de informações pessoais dos usuários e responsáveis vinculados ao sistema, classificados como ativos de alta criticidade.

Histórico Sensorial e de Eventos: Conjunto de registros gerados pelo funcionamento contínuo da pulseira inteligente, incluindo telemetria, eventos detectados e logs operacionais.

6.4 MATRIZ DE RISCOS DOS ATIVOS

Ativo	Impacto	Probabilidade	Nível de Risco
Banco de Dados Relacional (ACT-SW-03)	Alto	Médio	Alto
API Backend em Python (ACT-SW-02)	Alto	Médio	Alto
Microcontrolador ESP32 (ACT-HW-01)	Médio	Médio	Médio
Sensor MPU6050 (ACT-HW-02)	Médio	Baixo	Médio
Cadastro de Usuários (ACT-INF-01)	Alto	Alto	Crítico
Contatos de Emergência (ACT-INF-02)	Alto	Médio	Alto
Histórico de Telemetria e Quedas (ACT-INF-03)	Alto	Médio	Alto
Aplicativo Mobile (ACT-SW-01)	Médio	Médio	Médio

Figura 9 – Matriz de riscos dos ativos

6.4.1 Critérios de Avaliação de Risco

Critério	Descrição
Impacto	Mede os danos operacionais, financeiros, legais ou relacionados à privacidade.
Probabilidade	Avalia a chance de ocorrência de falhas, ataques ou indisponibilidade.
Nível de Risco	Resultado da combinação entre impacto e probabilidade.

Figura 10 – Critérios de avaliação de risco

O inventário de ativos do projeto FallSense serve como base para futuras etapas de análise de riscos, definição de controles de segurança e implementação de políticas de proteção de dados, fortalecendo a governança do ecossistema e ampliando a maturidade do sistema em relação às boas práticas de segurança da informação. A documentação dos ativos também contribui para a rastreabilidade operacional do

sistema, apoio a auditorias internas e evolução contínua das estratégias de proteção de dados e conformidade legal do projeto.

7 USO DE ARTIGOS CIENTÍFICOS E NORMAS TÉCNICAS

O desenvolvimento, a modelagem de ameaças e as auditorias de segurança da plataforma FallSense foram embasados em normas técnicas, leis federais e frameworks reconhecidos internacionalmente pela indústria de segurança da informação. A adoção dessas diretrizes assegura que o sistema atenda aos requisitos modernos de proteção de dados e resiliência contra ataques cibernéticos.

As principais normativas e documentos técnicos utilizados incluem:

- **Lei Geral de Proteção de Dados (LGPD - Lei nº 13.709/2018):** Utilizada como base legal para o tratamento dos dados pessoais e sensíveis (informações de saúde e geolocalização) dos usuários e pacientes monitorados, garantindo a aplicação dos princípios de finalidade, minimização e segurança.
- **OWASP API Security Top 10 (2023):** Framework empregado para identificar e mitigar os riscos mais críticos associados à comunicação entre o aplicativo mobile, o dispositivo IoT e a API FastAPI, com foco especial na prevenção de quebras de autenticação e esgotamento de recursos (*rate limiting*).
- **OWASP Top 10 Web Application Security Risks (2021):** Diretriz adotada para sanar vulnerabilidades de injeção e falhas de configuração de segurança no tráfego HTTP/HTTPS.
- **Penetration Testing Execution Standard (PTES) e NIST SP 800-115:** Metodologias utilizadas para estruturar e conduzir as auditorias e os testes de invasão (pentest) no ecossistema, garantindo a padronização das fases de pré-engajamento, coleta de informações, modelagem de ameaças e exploração.

REFERÊNCIAS

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018.

NIST – NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Technical Guide to Information Security Testing and Assessment (NIST SP 800-115).

Gaithersburg: NIST, 2008. Disponível em:

<https://csrc.nist.gov/publications/detail/sp/800-115/final>. Acesso em: 18 maio 2026.

OWASP – OPEN WORLDWIDE APPLICATION SECURITY PROJECT. API Security Top 10 2023. 2023. Disponível em: <https://owasp.org/API-Security/editions/2023/en/0x00-header/>.

Acesso em: 19 maio 2026.

OWASP – OPEN WORLDWIDE APPLICATION SECURITY PROJECT. OWASP Top 10 Web Application Security Risks 2021. 2021. Disponível em:

<https://owasp.org/www-project-top-ten/>. Acesso em: 19 maio 2026.

PTES – PENETRATION TESTING EXECUTION STANDARD. PTES Technical

Guidelines. 2014. Disponível em: <http://www.pentest-standard.org/>. Acesso em: 18 maio 2026.